WHITEPAPER NO. 3

Break It Before They Do

Authorized Hacking for Organizations Under Siege

Whitepaper No. 3

NOVEMBER 2026

William Aaron Turner, Founder & President
Infinitum Corporation, Washington, DC

Break It Before They Do: Authorized Hacking for Organizations Under Siege Practical, Integrated Steps for Mid-Size Organizations

Infinitum Corporation Whitepaper No. 3 · November 2026 · **Released November 8, 2026**

Neutrality statement. This paper draws general lessons about technology and conflict from public sources. It takes no side and makes no claim about any party.

© 2026 Infinitum Corporation. All rights reserved. No part of this publication may be reproduced or distributed without written permission, except for brief quotations with attribution.

DISCLAIMER

This whitepaper is provided for general information only. It is not legal, regulatory or professional advice for any specific situation, and it does not create a client relationship. Statistics are taken from the public sources cited and remain the property of their publishers; they describe the samples studied by those publishers and are not benchmarks or predictions for any particular organization. Infinitum Corporation makes no promise or guarantee about the security outcome any organization will achieve.

This paper is strictly analytical and defensive. References to irregular warfare, gray-zone competition and hybrid threats are used as an analytic lens for defense and resilience. Nothing in this paper is instruction for offensive activity. Any security testing referred to here means authorized, scoped testing performed with the written permission of the system owner.

Scenarios in Part VIII are illustrative and hypothetical. They do not describe any real organization, client or incident.

Trademarks and framework names belong to their respective owners. Citation of a source does not imply that its publisher endorses this paper or Infinitum Corporation.

CONTACT

Infinitum Corporation, Washington, DC · 1629 K Street NW, Suite 300
https://www.theinfinitumcorporation.com
info@theinfinitumcorporation.com
Telegram: https://t.me/infinitumcorporation · X: https://x.com/infinitumceo

All data comes from the public record. All conclusions are mine. — W.A.T.

Contents

Executive summary 4

The problem: the siege is already on 7

The siege, read by a security analyst 11

Analysis: walking your own walls 14

Part I: Know the difference. Four kinds of looking 14
Part II: Permission first. Authority that stands up 17
Part III: Scope like the besieger. See yourself from outside 21
Part IV: Demand a method you can audit 24
Part V: From findings to fixes. Repair the wall, then check the repair 28
Part VI: Test the sentries, not just the stone 32
Part VII: Buy testing like a professional 35
Part VIII: Three scenarios 39

Recommendations 42

Conclusion 48

About Infinitum Corporation 49

References 50

Glossary 52

Executive summary

By William Aaron Turner, Founder and President, Infinitum Corporation.

Someone is going to test your defenses. The only question is who goes first.

That is the whole argument of this paper. Every organization connected to the internet is already being probed. Scanners knock on every door, every day. Stolen passwords get tried against every login page that will accept them. Old flaws in old appliances get found by people who never had to ask permission. Nobody sends you the report.

So you have a choice. You can wait for the uninvited test, or you can commission an invited one. You can find the breach in your own wall, on your schedule, with your rules, and fix it before anyone else walks through it.

Key word: invited.

This paper is about authorized hacking. That means vulnerability assessment, penetration testing and red teaming done with written permission from the owner of the systems, inside an agreed scope, under rules of engagement, for one purpose: defense. Nothing else qualifies. Testing without permission is not a gray area. It is an attack.

I read security problems through one lens: irregular warfare. Joint doctrine describes it as a form of warfare in which state and non-state actors campaign "through indirect, non-attributable, or asymmetric activities," and says the term "seeks to create dilemmas and increase risk and costs to adversaries to achieve a position of advantage" (JP 1 Vol 1, as quoted in U.S. Army CALL, 2025). That is an analytic lens, nothing more. You do not need to care about doctrine. You only need to notice that the people working against your network behave the way it describes. They probe indirectly. They hide who they are. They spend little and make you spend a lot.

The organizing image for this paper is the siege. A city under siege is not usually taken by one great assault. It is taken because somebody found the one gate that was poorly watched, the stretch of wall that had crumbled, the guard who could be talked into opening a door. Defenders who survived sieges walked their own walls. They looked for the weak stones before the besiegers did. That is a comparison, not a claim that your office is a fortress or that anyone is shooting at it. **This paper draws general lessons about technology and conflict from public sources. It takes no side and makes no claim about any party.** It stays at the level of governance, scoping, rules of engagement, methodology and remediation. It contains no attack instructions, no exploit steps and no targeting content, by design.

Why now

Three findings from the public record stand out.

First, the way in has shifted toward the flaws you already know about. Verizon's 2026 Data Breach Investigations Report (DBIR) found that exploitation of vulnerabilities is now the most common initial access vector for breaches, at 31% of its reporting dataset, while credential abuse, the previous leader, is down to 13% (Verizon, 2026). In its analysis of small and medium-sized businesses, Verizon says many ransomware attacks are opportunistic, and that victims were hit because they had compromised credentials (38%) or unpatched vulnerabilities in edge devices (29%) (Verizon, 2026).

Second, the fixes are not keeping pace. Verizon reports that only 26% of the vulnerabilities in CISA's Known Exploited Vulnerabilities (KEV) catalog were fully remediated by organizations in 2025, down from 38% the year before. The median time to full resolution rose to 43 days from 32 (Verizon, 2026). As of the catalog version dated October 30, 2026, the KEV catalog lists 1,766 vulnerabilities with evidence of exploitation in the wild (CISA KEV, 2026).

Let that sink in. These are not theoretical weaknesses. They are flaws somebody has already used. And three out of four were not fully fixed.

Third, the bill is large and slow to arrive. IBM and the Ponemon Institute report that the global average cost of a data breach reached a record USD 4.99 million, and that the mean time to identify and contain a breach rose to 247 days. Breaches with lifecycles longer than 200 days cost more on average than shorter ones (USD 5.65 million against USD 4.32 million) (IBM and Ponemon Institute, 2026). In the same study, offensive security testing (red teaming, penetration or vulnerability testing) was one of the factors associated with lower breach costs, about USD 211,339 below the average when each of 30 factors was measured in isolation (IBM and Ponemon Institute, 2026). That is an association in one study's sample, not a promise. It is still worth knowing.

What authorized testing is, and is not

Testing is not one thing. The four kinds this paper covers answer four different questions.

- **Vulnerability scanning** asks: what known weaknesses can automated tools see? It is cheap, broad and shallow.
- **Vulnerability assessment** asks: of those weaknesses, which are real, and which matter most to us? It adds validation, context and ranking.
- **Penetration testing** asks: could an attacker actually get through, and how far? CREST describes it as "an ethical attack simulation intended to demonstrate or validate the effectiveness of security controls in a particular environment by highlighting risks posed by actual exploitable vulnerabilities" (CREST, 2022).
- **Red teaming** asks: would we notice, and would we respond? It tests the defenders as much as the defenses.

The UK National Cyber Security Centre (NCSC) adds a point most buyers miss. Penetration testing "should be viewed as a method for gaining assurance in your organisation's vulnerability assessment and management processes, not as a primary method for identifying vulnerabilities." It compares a

test to a financial audit (NCSC, 2017/2022). In an ideal world, the NCSC says, "you should know what the penetration testers are going to find, before they find it."

Don't take my word for it. That is the government's own guidance.

The seven moves

The recommendations come in seven moves, sized for a mid-size organization with a small security team.

1. **Know your walls.** Build the inventory first. You cannot authorize a test of systems you cannot name.
2. **Put permission in writing.** Signed authorization, a clear scope, rules of engagement, legal review and a stop condition, before anyone touches a keyboard.
3. **Scan continuously, assess regularly.** Make scanning a daily routine and assessment a scheduled one, so that the penetration test becomes an audit rather than a discovery exercise.
4. **Test what an adversary would actually do.** Scope tests around your crown assets and the routes the public data says are most used: the edge, stolen credentials, people and suppliers.
5. **Test the watchers, not just the walls.** Use red and purple exercises to measure detection and response, not only prevention.
6. **Turn findings into fixes, and prove they held.** Prioritize with exploitation evidence, assign every finding an owner and a date, find the root cause, and retest.
7. **Buy testing like a professional.** Choose qualified providers, contract for data handling and reporting you can use, and keep the program running year after year.

None of these moves needs an exotic product. All of them need discipline: permission before action, evidence before priority, and a retest before anyone says "fixed."

This paper includes a comparison of testing types, an authorization checklist, a rules-of-engagement outline, a 30/60/90-day plan, a 12-month roadmap, a 30-item self-assessment and three scenarios that are hypothetical and say so.

Every figure in this paper belongs to the source cited. I make no claim about the results any organization will achieve. Read the sources, then decide.

The problem: the siege is already on

Here is the uncomfortable truth about testing.

Your systems are tested every day already. Not by you. Automated scanners sweep the internet looking for exposed services. Credential lists harvested from other breaches are replayed against your login pages. Somebody, somewhere, is reading the same vendor advisories your team is reading, and deciding which of them can be turned into a way in.

None of those testers asked permission. None of them will share the findings. And they do not have to be good. They only have to be first.

IBM puts the imbalance in one line: attacks "can be launched for thousands while breaches cost millions" (IBM and Ponemon Institute, 2026). That is the economics of a siege. The besieger can probe a hundred stretches of wall for the price of one breach. The defender has to hold all of them.

What the evidence shows

I will keep this section to numbers I can trace to a source I opened. Every figure belongs to the publisher named, and describes that publisher's dataset.

Known flaws are now the main way in. Verizon's 2026 DBIR says exploitation of vulnerabilities "is now the most common initial access vector for breaches," rising to 31% in its reporting dataset, while credential abuse fell to 13% as an initial access vector (Verizon, 2026). Credentials have not gone away. They have been overtaken.

The flaws stay open. Verizon used the CISA KEV catalog as its subset of vulnerabilities that "all organizations are incentivized to patch." Only 26% of KEV vulnerabilities found in organizations' environments had been fully remediated, "a considerable drop from last year's 38%." The share left entirely unremediated rose to 16% from 12%. The median time to full patching rose to 43 days, "almost two weeks longer than last year's 32 days" (Verizon, 2026).

The pile is growing. The median number of KEV vulnerabilities an organization had to patch rose to 16 in 2025 from 11 in 2024, which Verizon calls "almost 50% more" (Verizon, 2026). The underlying dataset of vulnerability records grew from 68.7 million in 2022 to 527.3 million in 2025, almost eight times the volume (Verizon, 2026).

There may be a speed limit. Verizon found that by Day 7 after detection, somewhere between 60% and 70% of KEV vulnerabilities remain open "regardless of year, volume or organizational maturity." Organizations "at their very best only get to fix 30%–40% of KEV instances in the first week after detection, so choosing the correct ones to patch really is the key strategy" (Verizon, 2026). Verizon itself calls this "an initial measurement," not a law.

Read that twice. Even the best teams cannot fix everything quickly. The winners are the ones who pick the right things to fix first. That is what good assessment is for.

Old flaws are not safe flaws. Verizon reports that nearly half of the KEV vulnerabilities with detectable exploitation activity in a research partner's data showed "Persistent" exploitation, meaning activity could be detected on an average of 96% of days. Only 20% of the vulnerabilities in that category were registered in the CVE database in 2024 and 2025. "For the other 80%, organizations would have had about two years' advance notice in which to patch" (Verizon, 2026).

The opportunists favor the smaller targets. Of the ransomware cases where Verizon had information on organization size, it found about 96% of victims were small and medium-sized businesses (Verizon, 2026). It describes many of these attacks as opportunistic: victims were chosen because of compromised credentials (38%) or unpatched vulnerabilities in edge devices (29%), "not so much about industry or the revenue of the victims" (Verizon, 2026).

People remain in the path. Verizon found the human element present in 62% of breaches. Social Engineering was the third most common breach pattern at 16% of breaches. Pretexting reached 6% of all breaches, and phishing remained at 16% (Verizon, 2026). In phishing simulations, the median click rate in mobile-centric vectors, such as voice and text messaging, was 40% higher than via email (Verizon, 2026).

Suppliers widen the wall. Breaches with third-party involvement reached 48% of total breaches in Verizon's dataset, up from 30%, an increase of 60% (Verizon, 2026). IBM found that supply chain compromise was the second most common initial attack vector in the breaches it studied, and that a supply chain breach added about USD 227,250 to the average cost when measured in isolation (IBM and Ponemon Institute, 2026).

The defenders are stretched. ISC2 reports that 67% of respondents indicated a staffing shortage, and 90% reported one or more skills gaps on their cybersecurity teams (ISC2, 2024). In IBM's study, a security skills shortage was associated with about USD 179,635 in added breach cost (IBM and Ponemon Institute, 2026).

Where the sources differ

The sources do not all say the same thing, and I will not pretend they do.

Verizon finds vulnerability exploitation is now the top initial access vector in its dataset (Verizon, 2026). IBM finds phishing was the top attack vector "for the fourth year in a row" in the breaches it studied (IBM and Ponemon Institute, 2026). Those statements are not in conflict. They describe different samples, different methods and different definitions. Verizon analyzes a large body of incidents and breaches contributed by many partners. IBM studies a set of breached organizations in depth and models cost.

The lesson for testing is the same either way. Test the edge, because known flaws are the way in. Test the people and the processes around them, because social engineering is the way in. A program that tests only one is half a program.

The four failures

Organizations of a few hundred people rarely fail at testing because they never test. They fail in four more ordinary ways.

They test the wrong thing. A penetration test is scoped around what was easy to put in a contract, not around what an adversary would want. The crown systems, the supplier connections and the help desk stay out of scope. The report comes back clean. Nobody learned anything.

They test without permission that would stand up. The person who signed did not own all the systems in scope. A cloud provider or a managed service provider was never asked. Nobody wrote down what was forbidden. When something breaks, nobody knows who carries the risk.

They treat the report as the finish line. CREST lists, among the top six challenges organizations report, "assuming that by fixing vulnerabilities uncovered during a penetration test systems will then be 'secure'" (CREST, 2022). Findings sit in a PDF. A year later, the next test finds the same things.

They test once and call it assurance. The NCSC warns that a penetration test "can only validate that your organisation's IT systems are not vulnerable to known issues on the day of the test," and that "it's not uncommon for a year or more to elapse between penetration tests" (NCSC, 2017/2022). A test is a snapshot. The siege is a film.

The cost of the uninvited test

The uninvited test has a price, and it arrives late. IBM puts the mean time to identify and contain a breach at 247 days (IBM and Ponemon Institute, 2026). In the United States, IBM reports average breach costs exceeded all other countries and regions in its study, at a record USD 11.5 million (IBM and Ponemon Institute, 2026).

Ransom economics are shifting, too. Verizon reports ransomware present in 48% of breaches, up from 44%, while 69% of ransomware victims in its dataset did not pay, and the median ransom paid fell to USD 139,875 from USD 150,000 (Verizon, 2026). Fewer payments do not mean less damage. They mean the damage is being absorbed in downtime, recovery and lost trust instead.

What this paper is, and is not

This paper is a practical guide to commissioning, governing and using authorized security testing in a mid-size organization. It explains the differences between testing types, how to authorize and scope a test, what good methodology looks like at the level a buyer needs, how to turn findings into fixes, how to test detection and response, and how to choose a provider.

It is not a technical manual. It contains no attack techniques, exploit steps, tool instructions or targeting content. The public standards cited here, such as NIST SP 800-115, PTES, the OWASP testing guide and the CREST guide, are the right places for practitioners to go for methodology. The Penetration Testing Execution Standard itself notes that the standard "does not provide any technical guidelines as far as how to execute an actual pentest" and keeps those separate (PTES). I keep them out entirely.

And it is not a sales pitch dressed as research. Every statistic belongs to the source cited. Where I give my own judgment, I say so.

The siege, read by a security analyst

Before the analysis, the lens. I want to be precise about what the comparison claims and what it does not.

The framing

Irregular warfare is my analytic lens. Current U.S. joint doctrine, as quoted by the Army's Center for Army Lessons Learned, defines it as "a form of warfare where state and non-state actors campaign to assure or coerce states or other groups through indirect, non-attributable, or asymmetric activities, either as the primary approach or in concert with conventional warfare" (U.S. Army CALL, 2025). The same source says the term "seeks to create dilemmas and increase risk and costs to adversaries to achieve a position of advantage" (U.S. Army CALL, 2025).

Strip away the military context and three ideas are left. Indirect: work around strength rather than through it. Non-attributable: make it hard to know who did it. Asymmetric: spend little, force the other side to spend a lot.

Every one of those describes the people probing your network. They go around your firewall through a supplier or a help desk. They hide behind rented infrastructure and stolen accounts. They spend pennies on scanning and make you spend weeks on recovery.

The siege is the image I use to hold those ideas together. It is a comparison, not a claim. Your organization is not a fortress, and nobody is besieging it in any literal sense. But the logic of a siege maps onto defensive security in ways that are useful for a buyer of testing.

Five things every siege teaches

1. The wall is only as strong as its weakest stretch. A besieger does not attack the strongest gate. It walks the perimeter looking for the crumbling section, the unwatched postern, the culvert nobody thought of. Your attackers do the same with scanners and leaked credentials. Verizon's finding that unpatched edge devices and compromised credentials explain so many opportunistic ransomware cases among smaller businesses is the modern version (Verizon, 2026).

For testing: scope must follow the perimeter an adversary sees, not the one your asset register describes.

2. The besieger has time; the defender has a schedule. NIST says it plainly: testing "often has a narrow scope because of resource limitations—particularly in the area of time. Malicious attackers, on the other hand, can take whatever time they need" (NIST SP 800-115, 2008). Your test lasts two weeks. The siege does not end.

For testing: a single annual test cannot match a continuous adversary. Continuous scanning and scheduled assessment have to carry the load between tests.

3. Defenders who survive walk their own walls. The garrison that inspects its own defenses, repairs what it finds and drills its sentries holds longer than the one that trusts the stone. That is authorized testing in one sentence: you find the weak stretch first.

For testing: the goal is not a clean report. It is a list of repairs.

4. Most walls fall from the inside. History is full of gates opened by someone persuaded, paid or fooled. Verizon puts the human element in 62% of breaches and reports pretexting, a scheme built on a concocted trusted relationship, at 6% of all breaches (Verizon, 2026). IBM reports social engineering such as impersonating help desk staff in 13% of the attacks it studied (IBM and Ponemon Institute, 2026).

For testing: people and processes belong in scope, with careful rules, consent from leadership and respect for the staff involved.

5. Sentries matter as much as stone. A wall that is breached but watched is a problem. A wall that is breached and unwatched is a catastrophe. IBM's 247-day mean time to identify and contain is the cost of unwatched walls (IBM and Ponemon Institute, 2026).

For testing: test detection and response, not only prevention. That is what red teaming is for.

The adversary's three advantages, and the tester's answer

Adversary advantage	What it looks like on a network	What authorized testing gives back
Indirect approach	Entry through a supplier, a forgotten system or a person, not through the hardened front door	Scope built around realistic routes, including third parties and social engineering where authorized
Non-attribution	Activity that blends with normal administration and is hard to distinguish or trace	Exercises that measure whether your monitoring can tell the difference
Asymmetric cost	Cheap, automated probing against a defense that must be right everywhere	Prioritization that spends your limited effort on what is actually exploited

The answer to each advantage is not a product. It is information you could not get any other way: a controlled, permitted look at your own defenses through hostile eyes.

Where the comparison breaks

Every comparison has limits. This one has four.

A tester is not an enemy. The whole point of authorized testing is that the tester works for you, under your rules, and stops when you say stop. Treating testers as adversaries, inside the organization or out, poisons the program. They are the scouts you send to the wall, not the army outside it.

Your systems are not a battlefield. No one is going to be hurt by a misconfigured server the way people are hurt in war. The comparison is about logic and economics, not about stakes.

Law and ethics bind you, not them. Real attackers ignore the law. Your testers cannot and must not. NIST notes that "attackers are not bound by this constraint and use whatever techniques they feel necessary" while organizations "tend to avoid using testing techniques that impact systems or networks" (NIST SP 800-115, 2008). That gap is permanent. Good scoping narrows it. Nothing closes it.

The paper is not about any real conflict. I use the siege as a general image. I name no state, no army and no campaign, and I make no claim about any party.

The device: walk your own walls

The rest of the paper is organized around one habit: walk your own walls before someone else does. That habit has eight parts, covered in the Analysis.

1. Know the difference between the kinds of testing (Part I).
2. Get permission that stands up (Part II).
3. Scope the test the way an adversary would see you (Part III).
4. Demand a method you can audit (Part IV).
5. Turn findings into fixes, and prove they held (Part V).
6. Test the sentries, not just the stone (Part VI).
7. Buy testing like a professional (Part VII).
8. Rehearse with three hypothetical scenarios (Part VIII).

Analysis: walking your own walls

The analysis has eight parts. Each ends with what to do and what to measure.

Part I: Know the difference. Four kinds of looking

The most expensive mistake in testing is buying the wrong kind. CREST's research with organizations found that "understanding the difference between vulnerability scanning and penetration testing" was one of the top six challenges they reported, alongside "identifying what type of penetration test is required" (CREST, 2022).

So start with definitions. They are not academic. They decide what you pay for and what you learn.

Examination and testing

NIST draws the first line. Examinations "primarily involve the review of documents such as policies, procedures, security plans, security requirements, standard operating procedures, architecture diagrams, engineering documentation, asset inventories, system configurations, rulesets, and system logs." Testing "involves hands-on work with systems and networks to identify security vulnerabilities" (NIST SP 800-115, 2008).

Both matter. NIST warns that testing "is less likely than examinations to identify weaknesses related to security policy and configuration," and that "in many cases, combining testing and examination techniques can provide a more accurate view of security" (NIST SP 800-115, 2008). A good program reads the plans and walks the wall.

Vulnerability scanning

CREST describes vulnerability assessment, "sometimes referred to as 'scanning'," as "the use of automated tools to identify known common vulnerabilities in a system's configuration." Such tools "scan the information systems environment to establish whether security settings have been switched on and consistently applied – and that appropriate security patches have been deployed." It "does not exploit vulnerabilities identified to replicate a real attack, nor does it consider overall security management processes and procedures that support the system" (CREST, 2022).

Scanning is the sentry on the wall. It is cheap, repeatable and broad. It is also noisy and literal. A scanner reports what it can see from where it stands. It does not know which server holds your payroll.

For some organizations, scanning is available at no cost. CISA's Cyber Hygiene services include vulnerability scanning that "continuously monitors and assesses internet-accessible network assets," with weekly reports and ad-hoc alerts on urgent findings, including known exploited vulnerabilities, and

web application scanning that covers, among other things, the OWASP Top Ten (CISA Cyber Hygiene). CISA states the services are available to U.S.-based federal, state, local, tribal and territorial governments, and to public and private sector critical infrastructure organizations (CISA Cyber Hygiene). CISA also says enrolled organizations "typically reduce their risk and exposure by 40% within the first 12 months." That is CISA's own claim about its program. I report it as such.

Vulnerability assessment

In this paper, I separate scanning from assessment, even though some sources use the terms interchangeably. Assessment is what a skilled person does with scan results and everything else: validate them, remove false positives, add business context, and rank what matters. NIST's example of an assessment plan for a vulnerability assessment lists activities "such as port and service identification, vulnerability scanning, security configuration review, and password cracking" against agreed targets (NIST SP 800-115, 2008). The point is judgment, not volume.

The NIST Cybersecurity Framework 2.0 puts the outcome in one line: "Vulnerabilities in assets are identified, validated, and recorded" (NIST CSF 2.0, 2024, ID.RA-01). Identified, validated and recorded. Scanning does the first. Assessment does all three.

Penetration testing

A penetration test goes a step further. It asks whether a weakness can actually be used, and what follows if it is.

The NCSC defines it as "a method for gaining assurance in the security of an IT system by attempting to breach some or all of that system's security, using the same tools and techniques as an adversary might" (NCSC, 2017/2022). CREST calls it "an ethical attack simulation" built around a manual testing process (CREST, 2022).

NIST divides a penetration test into four phases: planning, discovery, attack and reporting. In the planning phase, "rules are identified, management approval is finalized and documented, and testing goals are set." NIST adds: "No actual testing occurs in this phase" (NIST SP 800-115, 2008). Remember that sentence. A large part of a good test happens before anyone tests anything.

Penetration tests come in different shapes. The NCSC describes a range by how much the testers are told. In transparent or open box testing, "full information about the target is shared with the testers." In opaque or closed box testing, "no information is shared with the testers about the internals of the target," which "more accurately models the risk faced from attackers that are unknown or unaffiliated to the target organisation," but "can also result in vulnerabilities remaining undiscovered in the time allocated for testing" (NCSC, 2017/2022). NIST makes the related distinction between external testing, conducted "from outside the organization's security perimeter," and internal testing (NIST SP 800-115, 2008).

There is a trade. The less you tell the tester, the more realistic the test, and the less of your estate it covers in the time you paid for. For most mid-size organizations, more information produces more value per day. Save the opaque test for the question it answers best: what does an unknown outsider see?

Red teaming

Red teaming is a different discipline with a different question. CREST quotes the UK Ministry of Defence Red Teaming Guide, which defines a red team as "a team that is formed with the objective of subjecting an organisation's plans, programmes, ideas and assumptions to rigorous analysis and challenge" (CREST, 2022). In security practice, the red team emulates an adversary to test whether the organization's people, processes and technology can detect and respond.

The European TIBER-EU framework, built for the financial sector, describes "threat intelligence-based ethical red-teaming" that mimics "the tactics, techniques and procedures of real-life attackers, based on bespoke threat intelligence." Its key line: "The outcome is not a pass or fail." The test is intended "to reveal the strengths and weaknesses of the cyber resilience measures put in place by the tested entity, with a focus on the learning effect of the test" (ECB, TIBER-EU).

Red teaming is powerful and easy to misuse. It is the last thing a young program needs, not the first. If you cannot keep up with your scan results, you are not ready to learn that your monitoring missed a simulated intruder. You already know.

Purple teaming

Purple teaming puts the attackers and defenders in the same room, on purpose. The red side runs an agreed activity. The blue side watches what its tools saw and what they missed. Both sides fix the gap together. TIBER-EU publishes separate purple-teaming guidance for how this is managed inside its testing and closure phases (ECB, TIBER-EU).

For a mid-size organization, purple exercises often deliver more learning per dollar than a covert red team, because nothing is wasted on secrecy. The goal is not to catch anyone out. It is to make the sentries better.

The comparison

	Scanning	Assessment	Penetration test	Red team	Purple exercise
Question	What known weaknesses are visible?	Which are real and which matter most?	Could an attacker get through, and how far?	Would we notice and respond?	Can we see and stop this specific behavior?
Depth	Broad, shallow	Broad, validated	Narrow, deep	Objective-driven	Narrow, collaborative

	Scanning	Assessment	Penetration test	Red team	Purple exercise
Who knows	Everyone	Everyone	Usually IT and security	A small control group	Everyone involved
Cadence	Continuous	Monthly or quarterly	Annually and after major change	When fundamentals are in place	Regularly, by theme
Main output	Finding list	Ranked, validated findings	Exploitable paths and fixes	Detection and response gaps	Tuned detections
Readiness needed	An inventory	A remediation process	Assessment under control	Detection and response in place	A team willing to learn in the open

Treat the cadence column as my judgment, not a standard. Your regulators, customers and risk appetite may require more.

What to do

- Write a one-page testing policy that defines these five activities in your own words and says who may commission each.
- Start or tighten continuous external scanning before buying a deeper test. If you are eligible, consider CISA's no-cost services.
- Match each test to the question you need answered. Write that question at the top of the scope.
- Do not buy a red team until scanning and assessment are under control.

What to measure

- Share of internet-facing assets covered by continuous scanning.
- For each test, whether the stated question was answered.
- Share of penetration test findings that your own assessment had already identified. The NCSC's ideal is that you know most of them in advance (NCSC, 2017/2022).

Part II: Permission first. Authority that stands up

This is the part of the paper I care about most.

Without permission, there is no such thing as ethical hacking. There is only hacking. The difference between a security test and a crime is a signature, a scope and a set of rules, made before the work starts, by people with the authority to make them.

NIST's glossary defines rules of engagement as "detailed guidelines and constraints regarding the execution of information security testing," established before the start of a test, that give the test team

"authority to conduct defined activities without the need for additional permissions" (NIST SP 800-115, 2008). Read the last phrase again. Authority to conduct defined activities. Not any activities. Defined ones.

Who may say yes

Permission has to come from someone who actually owns the risk and the systems. That sounds obvious. It is where many programs go wrong.

NIST says that if an organization "does not control part or all of its network, such as having a portion of its systems housed on a third party's network, the owner of the other network usually must also consent in writing to the assessment plan." It gives the example of shared systems, such as virtual machine platforms that serve several organizations. "By signing the assessment plan, all parties acknowledge and approve of the assessment" (NIST SP 800-115, 2008).

In a modern mid-size organization, that list of owners is long. Cloud platforms. Software-as-a-service providers. Managed service providers. Hosting companies. Payment processors. Each has its own terms on what customers may test and how. Some publish testing policies. Some require notice. Some forbid certain activities outright. Your contract with the tester does not override your contract with them.

My rule: if you do not own it outright, you get written permission from whoever does, or it is out of scope.

The law is part of scope

NIST recommends that legal advisors "always be involved for intrusive tests such as penetration testing." Legal departments "may assist in reviewing the assessment plan and providing indemnity or limitation of liability clauses into contracts," may require nondisclosure agreements, and "should also address any privacy concerns" (NIST SP 800-115, 2008). NIST notes that captured data "may include sensitive data that does not belong to the organization—or personal employee data, which may create privacy concerns" (NIST SP 800-115, 2008).

In the United States, the federal computer crime statute turns on authorization. When the Department of Justice revised its charging policy under the Computer Fraud and Abuse Act in 2022, it said that, for the first time, the policy "directs that good-faith security research should not be charged." It also said that "claiming to be conducting security research is not a free pass for those acting in bad faith," and that the policy focuses on cases where a defendant "is either not authorized at all to access a computer or was authorized to access one part of a computer" and accessed a part beyond it (DOJ, 2022).

That is a prosecutorial policy, not a safe harbor, and it is not legal advice. I cite it to make one point: authorization is the legal hinge. Testing inside it is defense. Testing outside it may be a crime, whatever the intent. Other countries have their own laws, and testing across borders raises its own questions. Ask counsel in every jurisdiction involved.

The authorization package

NIST describes an assessment plan, rules of engagement, or both, and suggests a short memorandum that testers can show to staff "as authorization to gain access to particular systems" (NIST SP 800-115, 2008). Whatever you call the documents, the package should answer these questions in writing.

Question	What the document must say
Who authorizes?	Named executive owner with authority over every system in scope, plus written consent from any third-party owners
Who tests?	The provider, the named testers, their qualifications, and any background checks your policies require
What is in scope?	Systems, applications, address ranges, locations and people, listed specifically
What is out of scope?	An explicit exclusion list. NIST says the plan "should also list specific systems … that are not authorized to be examined or tested" (NIST SP 800-115, 2008)
What is allowed?	Types and level of testing, at a level of detail that describes "the type of testing, approach, and tools" (NIST SP 800-115, 2008)
What is forbidden?	Prohibited activities stated "in a way that leaves no room for interpretation" (NIST SP 800-115, 2008)
When?	Dates, hours, blackout periods and change freezes
From where?	Source addresses and locations of testing, so administrators can tell testing from attack (NIST SP 800-115, 2008)
Who is on call?	Primary and alternate contacts on both sides, available at short notice, and an escalation path
What about data?	Storage, encryption, transmission, retention and destruction of any data the testers touch
What if something breaks?	Stop conditions, who can call a halt, and how service is restored
What if they find a real intruder?	Whether testing stops, who is told, and who decides when it resumes
Who else must know?	Requirements to inform parent organizations, insurers, regulators or incident response providers

That last row matters more than it looks. NIST says the plan should identify any requirements "to inform parent organizations, law enforcement, and a computer incident response team" and, for covert testing, define how detected test activity is handled, so that "assessment activity does not trigger reporting of security breaches to external parties" (NIST SP 800-115, 2008). Think about your cyber insurer and your managed security provider. A test that triggers a false breach notification is a test that went badly.

The real intruder clause

This one deserves its own heading. Testers sometimes find evidence that someone else got there first.

NIST asks the right questions: "if the assessors discover an actual intruder or an intruder's footprints within the network, should testing stop? If so, when can testing recommence—and by whose authority?" It says the plan "should provide clear-cut instructions" (NIST SP 800-115, 2008).

Decide in advance. In my view the default should be: stop the test, preserve what was seen, hand over to incident response under your existing plan, and restart only with fresh written authority. A test that keeps running over a live intrusion can destroy evidence and confuse the response.

People in scope

Social engineering tests touch real people. They deserve more care, not less.

The NCSC's description of scenario-driven testing and CREST's note that a penetration test "plays only a small part (despite often including social engineering tests) in reviewing the people element" both treat people as part of the picture (NCSC, 2017/2022; CREST, 2022). If people are in scope, add these to the package:

- Explicit leadership approval and, where your policies or law require it, review by human resources and counsel.
- A rule that results are reported as patterns and process gaps, not as names to be disciplined.
- A ban on pretexts that would cause real distress, exploit personal circumstances or impersonate emergency services, regulators or law enforcement.
- A debrief plan, so that the people involved learn something and are not simply embarrassed.

The purpose of testing people is to fix processes, such as how the help desk verifies a reset or how finance confirms a payment change. A test that makes staff afraid to report mistakes has made you weaker.

Stop means stop

Every authorization needs a stop. Name who can call it on each side, how it is communicated, and how fast testers must cease. Test the stop at the kickoff meeting. It takes two minutes and it will tell you whether the contacts actually answer.

THE TAKEAWAY

Permission is not paperwork. It is the line between defense and attack. Get it from every owner, in writing, before anyone touches anything.

What to do

- Adopt a standard authorization template based on the table above and NIST's rules-of-engagement outline in SP 800-115 Appendix B.
- List every third-party platform in scope and record the written permission or published testing policy for each.
- Involve counsel for every intrusive test. Decide the real-intruder clause and the stop procedure before kickoff.
- For any test involving people, add the people safeguards above.

What to measure

- Share of tests with a complete, signed authorization package before the start date.
- Number of third-party systems tested without recorded permission. The target is zero.
- Time from "stop" to cessation in the kickoff drill.

Part III: Scope like the besieger. See yourself from outside

A test is only as good as its scope. Scope too narrow, and the report is clean and useless. Scope too broad, and the testers spend their days skimming and you learn little about anything.

CREST's research found that "determining the depth and breadth of coverage of the test" was the first of the top six challenges organizations report, and "agreeing targets and frequency of tests" was another (CREST, 2022). This part is about getting both right.

Start from the crown, not the contract

Scope usually starts from what is easy to describe: a website, an address range, an office network. That is backward. Start from what you cannot afford to lose.

Name your crown assets. The systems and data whose loss, disclosure or corruption would hurt the organization most. Payroll and finance. Customer records. The operational system your revenue depends on. The identity system that controls access to everything else. Then work outward: what touches them, who administers them, which suppliers connect to them, and what an outsider can see of any of it.

CREST's guide recommends identifying target environments by considering, among other things, "all main internal systems that support your organisation," "their level of criticality to the business," and "details about important third-party suppliers" (CREST, 2022).

Let the evidence shape the routes

Public data tells you which routes adversaries use most. Use it to set priorities, adjusted for what you know about yourself.

Route	What the public data says	What to put in scope
The edge	Exploitation of vulnerabilities is now the most common initial access vector in Verizon's dataset, at 31%. Unpatched edge devices explain 29% of the opportunistic SMB ransomware cases it describes (Verizon, 2026)	Internet-facing systems: remote access gateways, firewalls, email and web services, exposed management interfaces
Credentials	Compromised credentials explain 38% of those SMB cases (Verizon, 2026). Small organizations in Verizon's data experienced a median of seven credential leak events over the year (Verizon, 2026)	Login surfaces, password policy, multifactor coverage, account recovery and help-desk reset processes
People	Human element in 62% of breaches; pretexting at 6% and phishing at 16% of breaches (Verizon, 2026)	Authorized social engineering tests aimed at processes such as reset verification and payment changes
Suppliers	Third-party involvement in 48% of breaches (Verizon, 2026). Supply chain compromise the second most common initial attack vector in IBM's study (IBM and Ponemon Institute, 2026)	Supplier connections and accounts, shared platforms (with the owner's written permission), and your own controls over supplier access
Web applications	The OWASP Top 10:2025 lists Broken Access Control first, followed by Security Misconfiguration and Software Supply Chain Failures (OWASP Top 10, 2025)	Customer portals and internal applications, tested against a recognized methodology
Internal depth	CISA's red team, in a mature organization, gained persistent access and moved across sites before reaching systems adjacent to sensitive business systems (CISA AA23-059A, 2023)	An assumed-breach test: what an attacker could reach from an ordinary workstation or account

Verizon's own advice on its statistics is the right attitude. Its report says to use its data "as your starting point, then gather evidence about your specific situation to determine if your risk is higher or lower than that baseline" (Verizon, 2026). In its worked example, a hospital uses its last penetration test results, among other evidence, to adjust its view of its own risk (Verizon, 2026). That is exactly how test results should feed back into planning.

The outside-in view

Before the test, get the besieger's view. What does the internet see of you? Which domains, addresses, services and cloud resources answer from outside? Compare that list to your asset register. The gaps are the forgotten gates.

This is also the single best use of an opaque, external test. The NCSC notes that closed box testing "more accurately models the risk faced from attackers that are unknown or unaffiliated to the target organisation" (NCSC, 2017/2022). An outsider who finds a system you did not know you had has given you the most valuable finding in the report.

Assume the wall is crossed

Some of the best scope questions start inside. Suppose an attacker already has one ordinary account and one ordinary laptop. What can they reach? How far is it from there to the crown?

An assumed-breach test answers that question directly, without spending your budget on the initial way in. It makes sense when you already know the way in exists. Verizon's numbers on credentials and edge devices suggest that, for many organizations, it does.

Depth versus breadth

Every scope trades depth against breadth for a fixed budget. The NCSC's model scoping output states "the timeframe and the amount of effort necessary to deliver the testing - usually given in terms of resource days" (NCSC, 2017/2022). Look at that number critically. Divide it by the number of systems in scope. If the answer is a few hours per system, you are buying a scan with a human signature on it.

My rule of thumb: test fewer things, more deeply, more often, and rotate the scope. A three-year rotation that tests the crown every year and everything else at least once is better than an annual test that touches everything and understands nothing.

When scope changes mid-test

Testers will find things outside scope. A connected system nobody listed. A supplier link that leads somewhere unexpected. The NCSC says the testing team "may either suggest a change to the scope, which is likely to alter testing time frames and cost, or they may recommend that the exclusion of such components be recorded as a limitation on testing," and that the decision "will generally be down to the risk owner" (NCSC, 2017/2022).

Write that process into the authorization. No tester should ever extend scope on their own initiative. Scope grows only with fresh written approval, and only from someone with authority over the new systems.

Special handling

Some systems need extra care. Operational technology. Medical devices. Payment systems. Fragile legacy applications. NIST notes that "any time that a test or tester directly interacts with a system or network, the potential exists for unexpected system halts and other denial of service conditions," and that organizations "should determine their acceptable levels of intrusiveness" and may exclude tests "known to create denial of service conditions" (NIST SP 800-115, 2008). Its example is a payroll database "deemed too mission-critical for a particular type of testing" placed on the exclusion list (NIST SP 800-115, 2008).

Exclusion is a decision, not a safe place. If a system is too fragile to test, it may be too fragile to survive a real attacker. Record the exclusion, record who accepted the risk, and find another way to assure it, such as configuration review, architecture review or a test against a faithful copy.

THE TAKEAWAY

Scope from the crown outward. Follow the routes the evidence says are used. Test fewer things more deeply. Never let scope grow without a signature.

What to do

- Name your crown assets and map what touches them before writing any scope.
- Compare the outside-in view with your asset register and fix the gaps.
- Build a multi-year rotation: crown every year, edge every year, everything else on a cycle.
- Include at least one assumed-breach objective in your next test.
- Record every exclusion with a named risk owner and an alternative form of assurance.

What to measure

- Share of crown assets tested in the past 12 months.
- Number of internet-facing assets discovered by testing that were not in the asset register.
- Effort per in-scope system, in tester hours.
- Number of exclusions without an alternative assurance method.

Part IV: Demand a method you can audit

You do not need to know how to run a penetration test to buy a good one. You do need to know what a good method looks like from the outside, so you can tell a disciplined engagement from an improvised one.

The NCSC warns that, by their nature, “penetration tests cannot be entirely procedural, an exhaustive set of test cases cannot be drawn up. Therefore, the quality of a penetration test is closely linked to the abilities of the penetration testers involved” (NCSC, 2017/2022). Skill matters. A recognized method is what makes skill consistent, repeatable and auditable.

This part stays at the buyer’s level. It describes the shape of the major public methodologies and what each should produce for you. It contains no techniques.

The public standards

NIST SP 800-115. NIST's *Technical Guide to Information Security Testing and Assessment* was published in September 2008. Its stated purpose is "to provide guidelines for organizations on planning and conducting technical information security testing and assessments, analyzing findings, and developing mitigation strategies." NIST says it is "not intended to present a comprehensive information security testing or assessment program," but "an overview of the key elements" (NIST SP 800-115, 2008). It is old in technology terms. Its governance guidance, on planning, rules of engagement, legal review, data handling and post-test mitigation, has aged well. It includes a rules-of-engagement template in Appendix B.

PTES. The Penetration Testing Execution Standard organizes a test into seven sections: pre-engagement interactions, intelligence gathering, threat modeling, vulnerability analysis, exploitation, post exploitation and reporting (PTES). Its authors describe the arc as running "from the initial communication and reasoning behind a pentest" through "reporting, which captures the entire process, in a manner that makes sense to the customer and provides the most value to it" (PTES). Note what comes first: pre-engagement, the conversations about scope and rules. And note what comes last: a report written for the customer.

OWASP. For web applications, the OWASP Web Security Testing Guide (WSTG) describes itself as "the premier cybersecurity testing resource for web application developers and security professionals." Version 4.2 is the current release, with version 5.0 in development (OWASP WSTG). The OWASP Top 10:2025 is "a standard awareness document for developers and web application security" that "represents a broad consensus about the most critical security risks to web applications" (OWASP Top 10, 2025). A test of your web applications should be able to say how it covered each relevant category.

CREST. CREST's *A Guide to Penetration Testing* (December 2022) frames testing as a program, not an event: three main stages, preparation, testing and follow up, supported by 22 detailed steps (CREST, 2022). In the testing stage, the steps run from agreeing testing style and type, identifying constraints and producing scope statements, through establishing a management assurance framework and using an effective testing methodology, to reporting key findings (CREST, 2022). Follow up includes remediating weaknesses and evaluating testing effectiveness.

NCSC. The NCSC's model engagement follows a simple pattern: "Initial engagement, scoping, testing, reporting and follow up. There should be a severity rating for any issues found" (NCSC, 2017/2022).

TIBER-EU. For red teaming in regulated finance, TIBER-EU guidance and templates cover phases "such as initiation, scoping, threat intelligence, red-team testing (planning and reporting), blue team report creation and remediation plan creation" (ECB, TIBER-EU). Even if you are not a bank, the shape is instructive. Intelligence first. Remediation plan last.

What the methods agree on

Read them side by side and the common shape is obvious.

Stage	NIST SP 800-115	PTES	NCSC model	CREST	What you should receive
Before	Planning (no testing occurs)	Pre-engagement interactions	Initial engagement, scoping	Preparation	Signed authorization package, scope, rules of engagement, test plan
Understand	Discovery	Intelligence gathering, threat modeling	Scoping	Research and planning	A short threat picture explaining why the scope looks the way it does
Test	Attack	Vulnerability analysis, exploitation, post exploitation	Testing	Identify and exploit vulnerabilities	Immediate notice of critical findings during the test
Report	Reporting	Reporting	Reporting	Report key findings	A report written for both leadership and engineers
After	Post-testing activities	—	Follow up	Follow up: remediate, improve	Root causes, remediation plan, retest

Every serious method begins before testing and ends after it. If a proposal from a provider jumps straight to "testing days" and ends at "report delivered," something is missing.

What a good report contains

The NCSC lists what a test report should include: "any security issues uncovered," "an assessment by the test team as to the level of risk that each vulnerability exposes the organisation or system to," "a method of resolving each issue found," "an opinion on the accuracy of your organisation's vulnerability assessment," and "advice on how to improve your internal vulnerability assessment process" (NCSC, 2017/2022). It recommends a debrief.

The last two items are the ones most reports leave out, and they are the ones that make a test an audit of your program rather than a list of bugs.

I would add four things a mid-size organization should insist on:

1. **An executive summary in plain language**, one page, saying what was tested, what was found, what it means for the business, and what to do first.
2. **Evidence sufficient to reproduce and verify**, handled under the data rules in your authorization, so your own engineers can confirm each finding and later confirm each fix.
3. **Root causes, not just symptoms.** Which process failure let each finding happen.
4. **A statement of limitations**: what was not tested, what time ran out on, and what scope exclusions were accepted.

Severity, with judgment

The NCSC notes that testers commonly use the Common Vulnerability Scoring System, and that CHECK reports state risk as high, medium, low or informational. It adds an important caution: other mitigating controls "could minimise the effectiveness of a vulnerability, or the presence of additional vulnerabilities could have a synergistic effect," and "any deviation from associating a vulnerability with its standard rating should be documented and justified" (NCSC, 2017/2022).

Then it says the most important sentence in its guidance for buyers: "risk assessment and decisions on the application of fixes are your responsibility. The test team may not have had access to all details about a specific system or the potential business impact" (NCSC, 2017/2022).

The tester rates. You decide.

Quality control on your side

You can check method quality without technical depth. Ask these questions of every engagement.

- Was the test plan written and approved before testing started?
- Did the provider tell you about critical findings during the test, or wait for the report?
- Do the findings map to the scope? Are there findings from outside scope? If so, how did that happen?
- Can your engineers reproduce each high-severity finding from the evidence given?
- Does the report state its limitations honestly?
- Did the testers comment on your own vulnerability assessment's accuracy?

THE TAKEAWAY

You do not need to know how to test. You need to know what a disciplined test looks like from outside: planned before, reported for the business, followed up after.

What to do

- Require providers to name the public methodology they follow, and map their phases to the table above.
- Write your report requirements into the contract, including the NCSC's five items and the four additions.
- Hold a debrief for every test, with engineering owners in the room.

What to measure

- Share of reports meeting your report requirements on first delivery.
- Share of high-severity findings your engineers could reproduce from the evidence provided.
- Number of reports with an explicit limitations section. The target is all of them.

Part V: From findings to fixes. Repair the wall, then check the repair

A test that ends with a report has failed. A test that ends with repairs, verified, has succeeded.

NIST puts it directly: "a security test is much more valuable if it also results in a mitigation strategy being developed and implemented." Mitigation recommendations, "including the outcome of the root cause analysis, should be developed for each finding" (NIST SP 800-115, 2008). CREST's research found organizations struggle with "remediating system vulnerabilities effectively" (CREST, 2022). This is where most programs leak value.

The prioritization problem

You will always have more findings than time. Verizon's data makes that concrete. Even top performers fix only 30% to 40% of KEV instances in the first week after detection, "so choosing the correct ones to patch really is the key strategy" (Verizon, 2026).

So how do you choose? Four public tools help. None is enough alone.

Severity: CVSS. The Common Vulnerability Scoring System, maintained by FIRST and now at version 4.0, describes the technical severity of a vulnerability (FIRST CVSS v4.0). Severity tells you how bad a flaw could be. It does not tell you whether anyone is using it.

Known exploitation: CISA KEV. CISA says it "maintains the authoritative source of vulnerabilities that have been exploited in the wild" and that organizations "should use the KEV catalog as an input to their vulnerability management prioritization framework" (CISA KEV, 2026). The catalog version dated October 30, 2026 lists 1,766 entries, of which 361 are flagged as known to have been used in ransomware campaigns (CISA KEV, 2026). For U.S. federal civilian agencies, Binding Operational Directive 22-01 set default remediation timelines from 2021: within six months for KEV vulnerabilities with a CVE ID assigned before 2021, and within two weeks for all others (CISA BOD 22-01). On June 10, 2026, CISA revoked it and replaced it with BOD 26-04, *Prioritizing Security Updates Based on Risk*. The new directive sets the urgency of remediation from four variables: whether the asset is publicly exposed, whether the vulnerability is on the KEV catalog, whether an adversary can automate exploitation, and whether exploitation gives partial or total control. CISA says its timeline table is "informed by the SSVC system," and its most urgent tier requires action within three days plus a forensic triage to check whether the system is already compromised (CISA BOD 26-04, 2026). Private organizations are not

bound by either directive. The logic of the new one is a useful model: exposure and exploitation first, everything else after.

Likelihood: EPSS. FIRST's Exploit Prediction Scoring System "estimates the probability that a published CVE will be exploited in the wild in the next 30 days," published daily for every CVE as a probability between 0 and 1 (FIRST EPSS). It is an estimate from a model. Treat it as a signal, not a verdict.

Decision: SSVC. CISA and Carnegie Mellon's Software Engineering Institute developed Stakeholder-Specific Vulnerability Categorization, a methodology that "accounts for a vulnerability's exploitation status, impacts to safety, and prevalence of the affected product." CISA's own decision tree sorts vulnerabilities into four decisions: Track, Track*, Attend and Act (CISA SSVC). The value of SSVC is that it ends in an action, not a number.

Where the sources point in different directions

The prioritization signals do not always agree, and Verizon's data adds a twist worth knowing.

KEV is a list of things that have been exploited. Verizon calls it "a timestamp and not a timeline": it "marks when a vulnerability reaches a critical mass of exploitation in the wild" (Verizon, 2026). Verizon's modeling of re-exploitation found that "the longer it's been since a vulnerability has been exploited, the less likely it is to be exploited again soon": the probability "drops by roughly half at 30 days, again at 90 days and again by half around nine months" (Verizon, 2026). It suggests that, faced with a choice between an older KEV entry with no recent activity and a non-KEV vulnerability with recent exploitation in your threat intelligence, "focusing on the one with recent activity could be a smarter bet." Verizon also cautions that automation of vulnerability discovery and exploit development by generative AI tooling "could upend" that pattern (Verizon, 2026).

At the same time, Verizon found that 80% of the "Persistent" exploitation category were older vulnerabilities, giving about two years' advance notice (Verizon, 2026). Old does not mean quiet.

My reading: KEV tells you what must be on the list. Exploitation recency and likelihood help you order the list. Your own context decides. Is it on the edge? Does it touch a crown asset? Is there a compensating control?

A simple ordering rule

For a mid-size team, I suggest a plain rule, adapted from the sources above. It is my synthesis, not a standard.

Priority	Condition	Target
1. Now	Confirmed exploitable by your tester, or KEV-listed, **and** internet-facing or on a path to a crown asset	Fix or isolate within days, and check whether the system is already compromised. Pre-authorize emergency change

Priority	Condition	Target
2. Next	KEV-listed or high exploitation likelihood, internal	Fix within your short service level, measured in days to a few weeks
3. Planned	High severity, no exploitation evidence, limited exposure	Fix in the normal cycle
4. Accept or track	Low severity, no exposure, or fully mitigated	Record a risk acceptance with an owner and a review date

Write the targets down. Publish them to the system owners. Measure against them.

Root cause: fix the process, not just the server

Individual findings are symptoms. NIST says "identifying the root cause of vulnerabilities is key to improving the organization's overall security posture because a root cause can often be traced to program-level weaknesses," and lists common root causes beginning with "insufficient patch management, such as failing to apply patches in a timely fashion or failing to apply patches to all vulnerable systems" (NIST SP 800-115, 2008). It notes that recommendations may be technical, such as "applying a particular patch," and nontechnical, addressing "the organization's processes," such as "updating the patch management process" (NIST SP 800-115, 2008).

For every high-severity finding, ask three questions:

1. **Why did it exist?** A missing patch, a default setting, an over-privileged account, a process gap.
2. **Why did we not know?** Was it invisible to our scanners, ignored in our queue, or outside our inventory?
3. **Where else does the same cause apply?** If one appliance was missed, which others share its owner, its patch process or its blind spot?

The third question is where a single finding becomes ten fixes.

The remediation register

Every finding goes into one register, with these fields at minimum:

- Finding, severity as reported, and your own risk rating.
- Affected systems and the crown assets they lead to.
- Root cause and the process change it implies.
- Named owner, not a team.
- Target date, based on your priority rule.
- Status: open, in progress, fixed pending retest, verified, or risk accepted.
- For risk acceptance, who accepted it, why, and when it will be reviewed.

The NIST Cybersecurity Framework expects exactly this loop. Its Improvement category includes “Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties” (NIST CSF 2.0, 2024, ID.IM-02).

Retest: the step most programs skip

“Fixed” is a claim. A retest is the evidence.

Agree a retest in the original contract, so that it is priced and scheduled rather than negotiated later. Retest every Priority 1 and 2 finding. Where root cause analysis produced a process change, test whether the process now works, not just whether the one server was patched.

Then close the loop with the next scan. A finding that reappears in three months tells you the fix did not stick. That is a process failure, and it belongs back in the register.

Measure the program, not just the findings

The strongest signal of a healthy program is repeat findings falling over time. CREST’s guide lists “evaluate penetration testing effectiveness” as a follow-up step (CREST, 2022). The NCSC’s ideal, that you know what testers will find before they find it, gives you a direct measure: what share of the test’s findings were already in your register (NCSC, 2017/2022)?

THE TAKEAWAY

Rank with evidence. Fix the cause, not just the symptom. Retest before you say "fixed." Measure whether the same findings come back.

What to do

- Adopt a written prioritization rule that uses KEV, exploitation likelihood and your own exposure.
- Put every finding in one remediation register with a named owner and date.
- Run root cause analysis on every high-severity finding and apply the “where else” question.
- Contract for retesting up front.

What to measure

- Median days to fix Priority 1 findings, against your target.
- Share of findings verified by retest.
- Repeat-finding rate from one test to the next.
- Share of test findings already in your own register before the test.

Part VI: Test the sentries, not just the stone

Prevention fails. Every serious framework assumes it. The question is what happens next. Does anyone notice? Does anyone act?

Penetration tests mostly measure the wall. Red and purple exercises measure the sentries.

The lesson from a mature organization

CISA published the findings of one of its own red team assessments in 2023. It is worth reading in full by anyone who runs a security program, and I will use it here only at the level of lessons, not techniques.

At the request of "a large critical infrastructure organization with multiple geographically separated sites," CISA conducted a red team assessment over a three-month period in 2022. The team "gained persistent access to the organization's network, moved laterally across the organization's multiple geographically separated sites, and eventually gained access to systems adjacent to the organization's sensitive business systems." Multifactor authentication prompts prevented access to one sensitive system (CISA AA23-059A, 2023).

Then the key sentence: "Despite having a mature cyber posture, the organization did not detect the red team's activity throughout the assessment, including when the team attempted to trigger a security response" (CISA AA23-059A, 2023).

Let that sink in. A mature organization, with real strengths, did not see a simulated intruder for months, even when the intruder tried to be seen.

CISA's advisory also lists what worked. "The organization conducts regular, proactive penetration tests and adversarial assessments and invests in hardening their network based on findings." From more than three million external in-scope addresses, the team found no easily exploitable services, which "forced the team to resort to phishing to gain initial access." Strong service account passwords, careful file shares, multifactor authentication on some sensitive systems and strong segmentation all slowed or blocked the team (CISA AA23-059A, 2023).

Two lessons. First, testing and hardening worked: the outer wall held, and the adversary had to go through people instead. Second, the sentries were the weak point. CISA's summary "highlights the importance of collecting and monitoring logs for unusual activity as well as continuous testing and exercises," and encourages organizations to "conduct regular testing within their security operations center" (CISA AA23-059A, 2023). It also recommends treating endpoint management systems, which "provide elevated access to thousands of hosts," as high value assets with additional restrictions and monitoring (CISA AA23-059A, 2023).

When to red team

Red teaming is a test of maturity. It is wasted on an organization that has not done the basics. My readiness test, in my own judgment, is three yes answers:

1. Scanning and assessment are continuous, and Priority 1 findings are fixed on time.
2. There is a monitoring capability, in-house or managed, with someone accountable for responding around the clock.
3. Leadership is ready to hear that the monitoring missed things, and to fund the fixes.

If any answer is no, spend the budget on the gap instead.

How to run one safely

The governance of a red team is more demanding than a penetration test, because fewer people know it is happening.

TIBER-EU's structure is a good model. It names five roles: the blue team, "whose prevention, detection and response capabilities are being tested without their foreknowledge"; a threat intelligence provider; the red-team testers; a control team, "a small team within the target entity whose members are the only ones there who know a test is happening and who lead and manage the test"; and, in its regulatory setting, an oversight team at the authority (ECB, TIBER-EU).

A mid-size organization will not have a regulator in the room. It still needs a control group. In my view the minimum is three people: an executive sponsor with authority over the whole scope, a senior security or IT leader who can deconflict in real time, and counsel. The control group holds the authorization, the stop, and the real-intruder clause from Part II.

NIST's guidance on covert testing applies with extra force: the plan must define how test activity detected by security staff is handled, "including as the escalation processes to be followed," so that it "does not trigger reporting of security breaches to external parties" (NIST SP 800-115, 2008). If your monitoring is outsourced, decide in advance whether the provider is in the control group or among the tested, and make sure the contract allows either.

Purple: learning in the open

For many mid-size organizations, the better first step is a purple exercise. The attackers and defenders agree on a set of behaviors based on threat intelligence. The red side performs each one, safely and within authorization. The blue side records what was logged, what alerted and what was missed. Then both sides fix the gaps together and run it again.

The NCSC describes a related idea: "scenario driven testing of detection and response capability," in which "the aim is to also gauge the detection and response capabilities your organisation has in place" (NCSC, 2017/2022).

The output of a purple exercise is not a report. It is a set of detections that now work, and a list of those that still do not.

The detection scorecard

Whether you run red or purple, score the sentries on the same five questions for each agreed behavior:

Question	Outcome to record
Was it logged?	Yes, partly, or no, and in which system
Did it alert?	Yes or no, and how long after the activity
Did a person look?	Yes or no, and how long after the alert
Was the response right?	Contained, escalated, ignored, or misclassified
What changes?	The fix to logging, detection, process or staffing

Track the scorecard over time. Your goal is fewer "no" answers each round. IBM's finding that breach lifecycles over 200 days cost more on average than shorter ones is the business case for every row (IBM and Ponemon Institute, 2026).

The machine-speed question

The public data hints that testing itself is changing. IBM reports that, among organizations deploying AI agents in their security operations centers, only 18% used them for vulnerability scanning and management, and that in follow-on research more organizations planned to deploy agents for penetration testing (52% against 33%) and for vulnerability scans and management (37% against 18%) (IBM and Ponemon Institute, 2026). These are stated plans, not results.

Automation will make some testing faster and cheaper. It does not change any rule in this paper. An automated test still needs written authorization, a scope, rules of engagement and a stop. A tool that can act needs tighter rules, not looser ones.

THE TAKEAWAY

A wall nobody watches is only a delay. Test whether the sentries see and act. Start with purple. Red team only when the basics hold.

What to do

- Score your detection with a purple exercise on three to five behaviors drawn from current threat intelligence.

- Define a control group and covert-test procedures before any red team.
- Treat systems that grant administrative access at scale, such as endpoint management, as crown assets in scope.
- Apply the same authorization rules to any automated or AI-assisted testing.

What to measure

- Share of agreed behaviors that were logged, alerted and answered, per round.
- Median time from simulated activity to human response.
- Number of detection gaps closed between rounds.

Part VII: Buy testing like a professional

Most mid-size organizations buy their testing. That is sensible. CREST notes that organizations "can carry out penetration testing themselves, sometimes very successfully. More often, they decide to use specialist third-party penetration testing providers" (CREST, 2022). Outside testers bring skills a small team cannot keep on staff, a fresh view, and independence.

Buying well is a skill of its own. CREST's research found organizations reported difficulties in "establishing a business case for a test to be undertaken," "understanding the costs of external services – and determining the true overall cost," and "finding a suitable penetration testing expert when required (e.g. at short notice)" (CREST, 2022).

The business case

Do not make the business case with fear. Make it with the evidence and your own numbers.

- **The exposure:** Verizon's findings on exploitation as the leading initial access vector, the 26% KEV full-remediation rate and the 43-day median (Verizon, 2026).
- **The cost of being late:** IBM's USD 4.99 million global average, the 247-day lifecycle, and the gap between breaches resolved inside and outside 200 days (IBM and Ponemon Institute, 2026).
- **The association:** IBM's finding that offensive security testing was associated with about USD 211,339 lower average breach cost when measured in isolation (IBM and Ponemon Institute, 2026). Present it honestly. It is a correlation in one study's sample, measured one factor at a time. It does not prove that testing caused lower costs, and it does not predict your result.
- **The trend:** Among breached organizations in IBM's study that planned to increase security investment, the share naming offensive security testing as an area of investment was 26%, down from 32% the year before (IBM and Ponemon Institute, 2026). You can read that as a gap worth closing.
- **Your own data:** Your outside-in view, your KEV backlog, your last test's repeat findings. These persuade more than any industry statistic.

Choosing a provider

CREST lists supplier selection criteria: the ability to provide a "solid reputation," "history and ethics," "high quality, value-for-money services," "research and development capabilities," "highly competent, technical testers," and "security and risk management, supported by a strong professional accreditation and complaint process" (CREST, 2022). The NCSC says third-party tests "should be performed by qualified and experienced staff only," and recommends that UK government organizations use testers and companies in its CHECK scheme (NCSC, 2017/2022).

Accreditations and certifications are useful signals. They are not guarantees. Ask about the people who will actually do your work.

Questions I would ask any provider, including mine:

1. Which public methodology do you follow, and how do your phases map to it?
2. Who exactly will test, what are their qualifications, and will they be the same people named in the proposal?
3. Show me a redacted sample report. Does it include an executive summary, root causes and limitations?
4. How do you handle data you touch during testing, during and after the engagement?
5. What happens if you find a critical issue mid-test? How fast will I hear?
6. What happens if you find evidence of a real intruder?
7. How do you avoid causing outages, and what is your record of incidents caused by testing?
8. Is a retest included? On what terms?
9. Do you subcontract any part of the work? If so, to whom, and under what controls?
10. What insurance do you carry, and what liability terms do you propose?

A provider who is uncomfortable with any of these questions has told you something.

Contract terms that matter

NIST's guidance on legal review applies to every testing contract: indemnity or limitation of liability clauses for intrusive testing, nondisclosure obligations, and privacy handling (NIST SP 800-115, 2008). Beyond those, put the following in writing.

Term	Why
Reference to the signed authorization package and rules of engagement	So that scope and rules are binding, not advisory
Named testers and approval for substitutions	So you get the skills you paid for

Term	Why
Data handling, retention and destruction	NIST lists storage, transmission and "removal of data from systems upon conclusion of the assessment" as plan requirements (NIST SP 800-115, 2008)
Critical finding notification within an agreed time	So that a serious flaw does not wait two weeks for a report
Report requirements	The NCSC's five items plus your additions (Part IV)
Retest included	So "fixed" is verified, not assumed
Confidentiality of findings	Findings describe your weaknesses. Treat them as sensitive
Stop and real-intruder procedures	So the control decisions in Part II are enforceable

Independence and rotation

Long relationships build knowledge. They also build blind spots. Many organizations rotate providers, or at least rotate testers, every few years so that fresh eyes see the wall. That is a common practice, not a rule I can cite to a standard. Weigh it against the value of a provider who knows your estate.

Whatever you decide, keep the testing provider separate from the people whose work it tests. A provider who built your network should not be the only one testing it.

Building internal capability

Buying testing does not mean outsourcing understanding. The NCSC's model assumes you have "an internal vulnerability assessment and management process" and that "a current vulnerability assessment should be shared with the testers" at scoping (NCSC, 2017/2022). That internal process is yours to own.

For a small team, internal capability means three things. Someone who runs and reads the scans. Someone who owns the remediation register. Someone who can read a test report critically and challenge it. ISC2 reports that 90% of respondents had one or more skills gaps on their cybersecurity teams (ISC2, 2024). If those three roles are not filled, fill them first, with staff, a managed service or a part-time advisor.

Supplier testing and your supply chain

Your suppliers are part of your wall. Verizon's 48% third-party involvement figure makes that plain (Verizon, 2026). You usually cannot test a supplier's systems. You can:

- Ask key suppliers for evidence of their own independent testing and remediation, under nondisclosure.

- Test your side of every supplier connection: the accounts, the access paths and the controls you own.
- Include supplier scenarios in your tabletop exercises.
- Write testing and notification expectations into supplier contracts at renewal.

The NIST Cybersecurity Framework explicitly includes "security tests and exercises, including those done in coordination with suppliers and relevant third parties" as a source of improvements (NIST CSF 2.0, 2024, ID.IM-02).

Receiving reports from outsiders

Sometimes the uninvited tester is friendly. A researcher finds a flaw and wants to tell you. The NIST Cybersecurity Framework includes an outcome for this: "Processes for receiving, analyzing, and responding to vulnerability disclosures are established" (NIST CSF 2.0, 2024, ID.RA-08).

A simple, published way to report a vulnerability, a named owner, and a commitment to respond is cheap. It turns some of the people walking your walls into allies. Write it with counsel, so that it is clear what you invite and what you do not.

THE TAKEAWAY

Buy on evidence, not fear. Ask hard questions of every provider. Contract for the report, the data, the stop and the retest. Keep enough capability in-house to challenge what you are told.

What to do

- Build the business case from public data and your own exposure numbers, and state the limits of the evidence.
- Use the ten questions and the contract terms above in your next procurement.
- Fill the three internal roles before expanding external testing.
- Publish a simple vulnerability disclosure process.

What to measure

- Share of engagements with named testers matching the proposal.
- Time from critical finding to notification, against the contract.
- Share of key suppliers that have provided evidence of independent testing.

Part VIII: Three scenarios

These three scenarios are **hypothetical**. They are not reports of real incidents, real organizations or real results. They contain no statistics and no techniques. They exist to show how the parts of this paper interact, and to give your team something to rehearse.

Each scenario is a mid-size organization, roughly a few hundred staff, with a small security team and several outside providers. Use them as prompts for a tabletop exercise. Replace the details with your own.

ILLUSTRATIVE · HYPOTHETICAL

Scenario one: The clean report

A regional professional services firm. One annual penetration test.

The setup. For three years, the firm has bought the same annual external test, scoped to its website and one address range. Each report comes back with a handful of medium findings. Leadership reads "no critical issues" and moves on.

The turn. A new IT manager compares the outside-in view with the asset register. She finds a remote access gateway, set up by a contractor two years earlier, that is not in the register and has never been in scope. It is running software with a flaw that appears in the KEV catalog.

What good looks like.

- The firm isolates the gateway the same day under a pre-authorized emergency change, then patches it.
- Incident response checks whether anyone used the flaw before the fix. The scope of that check is decided by counsel and the incident response provider, not by the testers.
- The next test is rescoped from the crown outward, with the outside-in view as its starting point.
- Root cause analysis finds the process gap: contractor-built systems were never added to the register. The fix is a change process, not just a patch.

Questions for your tabletop. When did we last compare what the internet sees with what our register says? Who can authorize an emergency change? Would our test have found this?

ILLUSTRATIVE · HYPOTHETICAL

Scenario two: The test that found someone else

A manufacturing company. An internal assumed-breach test.

The setup. The company commissions an assumed-breach test starting from an ordinary employee laptop. The authorization package includes a real-intruder clause.

The turn. On day four, the testers notice an account behaving in ways their plan does not explain. It is not them. They stop, as the clause requires, and call the named contact.

What good looks like.

- The contact answers within minutes, because the stop drill at kickoff proved the number worked.
- The testers preserve their notes and hand over to the company's incident response provider under the existing plan. They do not investigate further on their own.
- Leadership decides, with counsel, whom to notify. The insurer's requirements were already listed in the authorization.
- Testing resumes two weeks later under a fresh written authorization, with the scope adjusted to what the response found.

What bad looks like. No clause, no stop, no contact. The testers keep going, the intruder notices, evidence is lost, and nobody knows who was allowed to do what.

Questions for your tabletop. Does our authorization say what happens if testers find a real intruder? Who decides when testing restarts?

ILLUSTRATIVE · HYPOTHETICAL

Scenario three: The help desk call

A healthcare services provider. An authorized social engineering test.

The setup. Leadership, human resources and counsel approve a limited test of the help desk's password reset process. The rules forbid pretexts involving emergencies, regulators or personal distress. Results will be reported as process findings, not names.

The turn. A tester, following the approved pretext, calls the help desk asking for a reset for a senior manager said to be traveling. The agent, under time pressure and with no call-back rule, completes the reset.

What good looks like.

- The tester reports the result to the control contact immediately. The account is restored and the reset is reversed within the hour.
- The debrief, with the help desk team present, focuses on the missing verification step. Nobody is blamed.
- The process changes: privileged and executive resets require a call-back to a number already on file, and a second approver.

- A retest a month later, under the same rules, confirms the new step is followed.

Questions for your tabletop. How does our help desk verify a reset for a senior or traveling user? Would our staff feel safe reporting that they were fooled?

What the scenarios share

Each turns on a decision made before the test. An inventory compared with the outside-in view. A real-intruder clause and a working stop. People safeguards and a no-blame debrief. None depended on a clever tester or an expensive tool. All depended on governance.

Run one scenario a quarter. Change the details. Write down what you find.

Recommendations

Here is the plan.

It is not glamorous. It is a garrison's routine: know the walls, get permission, look every day, test properly, repair, check the repair, and drill the sentries. The eight parts above each end with their own actions. This section puts them in order.

Timelines depend on your team size, your providers and your risk appetite. The phases below are a sequence first and a schedule second.

The seven moves

#	Move	Part it draws on	First proof that it is working
1	**Know your walls.** Name crown assets, build the inventory, compare it with the outside-in view.	III	The outside-in list matches the register
2	**Put permission in writing.** Standard authorization package, third-party consents, legal review, stop and real-intruder clauses.	II	Every test in the past year started with a complete signed package
3	**Scan continuously, assess regularly.** Daily external scanning, scheduled validated assessment.	I, V	Penetration test findings were mostly already in your register
4	**Test what an adversary would actually do.** Scope from the crown outward along the routes the evidence says are used.	III, IV	Crown assets and the edge tested in the past 12 months
5	**Test the watchers, not just the walls.** Purple exercises first, red team when ready.	VI	Detection scorecard improves round over round
6	**Turn findings into fixes, and prove they held.** Evidence-based priority, one register, root causes, retests.	V	Priority 1 fixes on time and verified by retest
7	**Buy testing like a professional.** Hard questions, strong contracts, internal capability to challenge results.	VII	Contracts include report, data, stop and retest terms

THE TAKEAWAY

Inventory before testing. Permission before action. Evidence before priority. Retest before "fixed."

What the siege teaches the plan

Each lesson of the siege maps to a part of the plan. Use this as a check on your own program.

Siege lesson	What it teaches	Where it lands in the plan
The wall is only as strong as its weakest stretch	Scope to the perimeter an adversary sees	Outside-in view; edge in scope every year
The besieger has time; the defender has a schedule	One test a year cannot match a continuous adversary	Continuous scanning; scheduled assessment; rotation
Defenders who survive walk their own walls	Find the weak stretch first	Authorized testing as routine, not event
Most walls fall from the inside	People and processes are in the path	Authorized social engineering with safeguards
Sentries matter as much as stone	Detection and response decide the cost	Purple and red exercises; detection scorecard

The first 90 days

Days 1 to 30: Know the walls and set the rules

- Name an accountable owner for the testing program, with authority to commission tests and to stop them.
- Write the one-page testing policy that defines scanning, assessment, penetration testing, red teaming and purple exercises.
- List crown assets. Build or refresh the inventory of internet-facing systems.
- Start continuous external scanning, or confirm the coverage of what you have. If you are eligible, consider CISA's no-cost Cyber Hygiene services.
- Adopt a standard authorization package based on Part II and NIST SP 800-115 Appendix B.
- List every third-party platform you rely on and record its testing policy or the permission you will need.
- Set up the remediation register and the written prioritization rule from Part V.

Days 31 to 60: Close the known gaps

- Triage the scan results against the KEV catalog and your exposure. Fix or isolate Priority 1 items.
- Run root cause analysis on the worst ten findings and apply the "where else" question.
- Compare the outside-in view with the register. Add or retire the strays.
- Write the scope for your next penetration test from the crown outward. Include the edge and one assumed-breach objective.
- Procure the test using the questions and contract terms in Part VII. Include a retest.

Days 61 to 90: Test and learn

- Hold the kickoff. Drill the stop. Confirm the real-intruder clause and contacts.
- Run the test. Require same-day notice of critical findings.
- Hold the debrief with engineering owners present. Load every finding into the register with an owner and date.
- Run one tabletop based on a scenario from Part VIII.
- Report to leadership: what was tested, what was found, what was fixed, what remains, and what it will take.

The first 12 months

Period	Focus	Key activities	Gate to move on
Months 1–3	Inventory, rules and baseline	Policy; authorization package; continuous scanning; register; first test scoped and run	Signed package for every test; Priority 1 items owned
Months 4–6	Remediation and retest	Priority 1 and 2 fixes; root cause process changes; retest; disclosure process published	Retest verifies Priority 1 fixes; repeat-finding rate recorded
Months 7–9	Watch the sentries	First purple exercise on three to five behaviors; detection fixes; supplier evidence requests	Detection scorecard baseline set and first gaps closed
Months 10–12	Widen and deepen	Web application testing against OWASP guidance; authorized social engineering test of one process; decide on red team readiness	Annual program review; three-year rotation agreed

A few rules hold across the whole year.

- No test starts without a complete, signed authorization package.
- Every finding has a named owner and a date.
- Nothing is called fixed until it is retested.
- Every quarter, leadership sees the register, the scorecard and what went wrong.
- Every year, re-run the self-assessment below.

The authorization checklist

Use this before every test. Every box must be ticked.

☐ A named executive with authority over every in-scope system has signed.

☐ Every third-party owner of in-scope systems has consented in writing, or its published testing policy has been checked and recorded.

☐ Systems, applications, address ranges, locations and people in scope are listed specifically.

- ☐ Systems out of scope are listed explicitly.
- ☐ Allowed and forbidden activities are stated in writing, without room for interpretation.
- ☐ Dates, hours, blackout periods and source locations of testing are recorded.
- ☐ Primary and alternate contacts on both sides are named and have been tested.
- ☐ Data handling, retention and destruction terms are agreed.
- ☐ Stop conditions and the person who can call a halt are named.
- ☐ The real-intruder clause says what happens and who decides when testing resumes.
- ☐ Insurers, managed providers and others who must be told have been identified.
- ☐ Counsel has reviewed the package for any intrusive testing.
- ☐ For tests involving people, leadership approval and people safeguards are in place.

Maturity self-assessment

Use this checklist with your security, IT and leadership teams. Answer honestly. A “no” is not a failure. It is a work item.

Score each item: 0 = not in place, 1 = partly in place, 2 = fully in place and evidenced. The levels at the end are my rough guide, not a formal standard.

Governance

- ☐ A named owner is accountable for the testing program and can commission and stop tests.
- ☐ A written policy defines scanning, assessment, penetration testing, red teaming and purple exercises.
- ☐ A standard authorization package is used for every test.
- ☐ Counsel reviews every intrusive test.
- ☐ Leadership receives a quarterly report on testing, findings and remediation.
- ☐ A vulnerability disclosure process is published and has an owner.

Inventory and scope

- ☐ Crown assets are named and mapped.
- ☐ The internet-facing inventory is compared with the outside-in view at least quarterly.
- ☐ Third-party platforms in scope have recorded permissions or testing policies.
- ☐ Scope is set from the crown outward, using public data and your own evidence.
- ☐ A multi-year rotation ensures every significant system is tested on a cycle.
- ☐ Every exclusion has a named risk owner and an alternative form of assurance.

Scanning and assessment

- ☐ Internet-facing assets are scanned continuously.

- ☐ Internal assets are scanned on a defined schedule.
- ☐ Scan results are validated and ranked by a skilled person.
- ☐ KEV status and exploitation likelihood are used in prioritization.
- ☐ A current assessment is shared with penetration testers at scoping.
- ☐ Most findings from the last penetration test were already in the register.

Testing and method

- ☐ Providers name and follow a recognized public methodology.
- ☐ Critical findings are reported during the test, within an agreed time.
- ☐ Reports include an executive summary, root causes and limitations.
- ☐ Web applications are tested against recognized OWASP guidance.
- ☐ Social engineering tests, if any, follow written people safeguards.
- ☐ Detection and response are tested with purple or red exercises.

Remediation and improvement

- ☐ Every finding is in one register with a named owner and date.
- ☐ A written prioritization rule sets target times by priority.
- ☐ High-severity findings get root cause analysis and the “where else” question.
- ☐ Priority 1 and 2 fixes are verified by retest.
- ☐ Repeat findings are tracked from test to test.
- ☐ Risk acceptances have an owner, a reason and a review date.

Reading your score

There are 30 items, for a maximum of 60 points.

- **0–20: Foundational.** Focus on inventory, authorization and continuous scanning before buying deeper tests.
- **21–40: Developing.** Penetration testing is worthwhile. Prioritize remediation, retest and root cause.
- **41–60: Established.** Consider purple exercises and, when ready, red teaming, with continued rotation and review.

Whatever your score, the next step is the same: pick the three lowest items that matter most to your risk, assign owners and dates, and re-score in a quarter.

The program scorecard

Report these to leadership every quarter. Measure against your own baseline, not anyone else’s.

Measure	Why it matters
Internet-facing assets found by testing that were not in the register	Measures whether you know your walls
Share of tests with a complete signed authorization package	Measures whether permission comes first
Median days to fix Priority 1 findings	Measures speed where it counts
Share of findings verified by retest	Measures whether “fixed” is true
Repeat-finding rate	Measures whether root causes are being fixed
Share of test findings already in your register	Measures whether your own assessment works
Detection scorecard: logged, alerted, answered	Measures whether the sentries see and act

Conclusion

The research points one way.

Known flaws are now the most common way in, in Verizon's data. Most of the flaws already known to be exploited are not fully fixed, and the median time to fix them is rising. The opportunists favor smaller organizations, and they get in through the edge and through stolen credentials. Breaches take months to find and contain, and the long ones cost more (Verizon, 2026; IBM and Ponemon Institute, 2026).

The irregular warfare lens explains why this keeps happening. Your adversaries work indirectly, avoid attribution and impose costs asymmetrically. They probe every stretch of the wall because probing is cheap. They do not need permission and they do not share the report.

You cannot stop them probing. You can make sure that when they arrive, the weak stretch has already been found and repaired, by people you invited, under rules you wrote.

That is what authorized testing is. Not a stunt. Not a certificate. A disciplined habit of walking your own walls: knowing what you have, getting permission before anyone touches it, looking every day, testing properly, fixing the cause, checking the fix, and drilling the sentries until they see what they are supposed to see.

The public guidance agrees on the shape. NIST says testing has its greatest value when it ends in mitigation (NIST SP 800-115, 2008). The NCSC says you should know what the testers will find before they find it (NCSC, 2017/2022). CREST says a test is "only a snapshot of a system at a point in time," and counts the assumption that fixing what one test found makes systems "secure" among the top challenges organizations face (CREST, 2022). TIBER-EU says the outcome is not a pass or fail (ECB, TIBER-EU). They are all describing a program, not an event.

Break it before they do. Then fix it. Then check.

Infinitum Corporation helps organizations take these steps in a way that fits their size, systems and risk appetite. Our testing work is always authorized, scoped and approved in writing, and performed for defense. I make no promise about the outcome any organization will achieve, and every figure in this paper belongs to the source cited.

Don't take my word for it. Read the sources, then decide.

This is the third paper in the series. The next is *Read the Enemy: Strategic Risk in the Gray Zone*.

Let's stay engaged. Write to info@theinfinitumcorporation.com, or visit https://www.theinfinitumcorporation.com. Dialogue is key.

About Infinitum Corporation

Infinitum Corporation is a technology and security consulting firm headquartered in Washington, DC, delivering practical, integrated security solutions.

Our work spans cybersecurity consulting, network architecture and defense, vulnerability assessment and ethical hacking, IT security, AI for security operations, strategic risk assessment and emerging defense technology advisory. Our ethical hacking work is always authorized, scoped and approved in writing, and performed for defense.

William Aaron Turner is Founder and President.

Website	https://www.theinfinitumcorporation.com
Email	info@theinfinitumcorporation.com
Telegram	https://t.me/infinitumcorporation
X	https://x.com/infinitumceo
Address	1629 K Street NW, Suite 300, Washington, DC

References

1. CISA (Cybersecurity and Infrastructure Security Agency). (2021, November 3). *BOD 22-01: Reducing the Significant Risk of Known Exploited Vulnerabilities* (revoked June 10, 2026, and superseded by BOD 26-04; archived page). https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities (cited as CISA BOD 22-01)
2. CISA. (2026, June 10). *BOD 26-04: Prioritizing Security Updates Based on Risk.* https://www.cisa.gov/news-events/directives/bod-26-04-prioritizing-security-updates-based-risk (cited as CISA BOD 26-04, 2026)
3. CISA. (2026). *Known Exploited Vulnerabilities Catalog* (web catalog and JSON feed, catalog version 2026.10.30, released October 30, 2026; 1,766 entries). https://www.cisa.gov/known-exploited-vulnerabilities-catalog (cited as CISA KEV, 2026)
4. CISA. (2023, February 28). *CISA Red Team Shares Key Findings to Improve Monitoring and Hardening of Networks* (Cybersecurity Advisory AA23-059A; used here for its findings, strengths and recommendations only, not its techniques). https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-059a (cited as CISA AA23-059A, 2023)
5. CISA. *Cyber Hygiene Services.* https://www.cisa.gov/cyber-hygiene-services (cited as CISA Cyber Hygiene)
6. CISA. *Stakeholder-Specific Vulnerability Categorization (SSVC).* https://www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc (cited as CISA SSVC)
7. CREST (Creasey, J.). (2022, December). *A Guide to Penetration Testing.* https://www.crest-approved.org/wp-content/uploads/2023/04/A-Guide-to-Penetration-Testing-2022.pdf (cited as CREST, 2022)
8. European Central Bank. *What is TIBER-EU?* https://www.ecb.europa.eu/paym/cyber-resilience/tiber-eu/html/index.en.html (cited as ECB, TIBER-EU)
9. FIRST (Forum of Incident Response and Security Teams). *Common Vulnerability Scoring System v4.0.* https://www.first.org/cvss/v4-0/ (cited as FIRST CVSS v4.0)
10. FIRST. *Exploit Prediction Scoring System (EPSS).* https://www.first.org/epss/ (cited as FIRST EPSS)
11. IBM and Ponemon Institute. (2026). *Cost of a Data Breach Report 2026.* https://assets.ibm.com/adobe/assets/urn:aaid:aem:21111142-1251-4369-86fb-57b82f5bb108/original/as/Cost%20of%20a%20Data%20Breach%20Report%202026.pdf (cost-factor figures from Figure 33; investment-area figures from Figure 39)
12. ISC2. (2024, October 31). *2024 ISC2 Cybersecurity Workforce Study.* https://www.isc2.org/Insights/2024/10/ISC2-2024-Cybersecurity-Workforce-Study
13. National Cyber Security Centre (UK). (2017, August 8; reviewed 2022, January 10). *Penetration testing: How to get the most from penetration testing.* https://www.ncsc.gov.uk/guidance/penetration-testing (cited as NCSC, 2017/2022)
14. NIST. (2024, February 26). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29 (cited as NIST CSF 2.0, 2024)
15. NIST (Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A.). (2008, September). *Technical Guide to Information Security Testing and Assessment* (SP 800-115). https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf (cited as NIST SP 800-115, 2008)
16. OWASP Foundation. *OWASP Top 10:2025.* https://owasp.org/Top10/2025/ (cited as OWASP Top 10, 2025)
17. OWASP Foundation. *Web Security Testing Guide* (project page; v4.2 current release, v5.0 in development). https://owasp.org/www-project-web-security-testing-guide/ (cited as OWASP WSTG)
18. PTES. *The Penetration Testing Execution Standard* (main page, read via the Internet Archive snapshot of December 30, 2025, because the live site did not respond). http://www.pentest-standard.org/index.php/Main_Page (cited as PTES)

19. U.S. Army Center for Army Lessons Learned. (2025, July 11). *Understanding Irregular Warfare* (No. 25-897), quoting the DOD definition from JP 1 Vol 1, *Joint Warfighting*. https://www.army.mil/article/286976/understanding_irregular_warfare (used only for its definition of irregular warfare; cited as U.S. Army CALL, 2025)

20. U.S. Department of Justice, Office of Public Affairs. (2022, May 19). *Department of Justice Announces New Policy for Charging Cases under the Computer Fraud and Abuse Act* (press release 22-533). https://www.justice.gov/archives/opa/pr/department-justice-announces-new-policy-charging-cases-under-computer-fraud-and-abuse-act (cited as DOJ, 2022)

21. Verizon. (2026). *2026 Data Breach Investigations Report.* https://www.verizon.com/business/resources/Te26/reports/2026-dbir-data-breach-investigations-report.pdf (cited as Verizon, 2026)

Note on in-text tags. Short tags refer to the entries above as marked. All sources were opened and read on November 2, 2026 (UTC+3). Where a source is quoted, the words are the source's own. Where a number is cited, it belongs to that source and describes that source's dataset or program. CISA's 40% figure for its Cyber Hygiene services is CISA's own statement about its program. IBM's cost-factor figures measure each factor in isolation against the global average and show association, not cause. The paper names no belligerent and draws on no party-specific battlefield material; the siege is used as a general image only.

Glossary

Assumed-breach test. A test that starts from a position inside the organization, such as an ordinary account or device, to measure how far an attacker could reach.

Authorization package. The signed documents that permit a test: scope, rules of engagement, consents, contacts, data terms and stop conditions.

Blue team. The people who defend the organization's systems, and whose detection and response are measured in red and purple exercises.

Control group (control team). The small group inside the tested organization that knows a covert test is happening and manages it.

Crown assets. The systems and data whose loss would most damage the organization.

CVSS. The Common Vulnerability Scoring System, maintained by FIRST, which rates the technical severity of a vulnerability.

EPSS. The Exploit Prediction Scoring System, maintained by FIRST, which estimates the probability that a published vulnerability will be exploited in the next 30 days.

Examination. In NIST's usage, a review of documents, configurations, rulesets and logs, as distinct from hands-on testing.

Irregular warfare. Defined by DOD as a form of warfare in which state and non-state actors campaign through indirect, non-attributable or asymmetric activities. Used in this paper as an analytic lens only.

KEV. CISA's Known Exploited Vulnerabilities catalog: vulnerabilities with evidence of exploitation in the wild.

Opaque (closed box) and transparent (open box) testing. Tests in which the testers are given no information, or full information, about the target.

Penetration test. An authorized, scoped exercise in which testers attempt to identify and safely demonstrate exploitable weaknesses, under written permission, so they can be fixed.

Purple exercise. A collaborative exercise in which attackers and defenders work together to test and improve specific detections.

Red team. A team that emulates an adversary, under authorization, to test whether the organization's people, processes and technology detect and respond.

Remediation register. A single record of every finding, its owner, priority, root cause, target date and status.

Retest. A follow-up test that verifies a finding has actually been fixed.

Root cause analysis. Identifying the process or program weakness that allowed a finding to exist.

Rules of engagement (ROE). In NIST's words, detailed guidelines and constraints regarding the execution of information security testing, established before the test.

Social engineering test. An authorized test of how people and processes respond to deception, run with leadership approval and safeguards.

SSVC. Stakeholder-Specific Vulnerability Categorization, a decision method that ends in an action: Track, Track*, Attend or Act in CISA's version.

Vulnerability assessment. A systematic review that identifies, validates and ranks security weaknesses, without necessarily attempting to exploit them.

Vulnerability scanning. The use of automated tools to identify known weaknesses and missing patches.